Type 1: Research Project

AMRITA VISHWA VIDYAPEETHAM
DEEMED TO BE UNIVERSITY UNDER SECTION 3 OF UGC ACT, 1956

EPSS-Augmented Multi-Factor CVE Prioritization for Container Images in DevSecOps Pipelines

Team Number: [75]

S.No	Register Number	Student Name
1	CB.SC.U4CSE23504	ASHIN VARGHESE
2	CB.SC.U4CSE23559	ANURUP R KRISHNAN
3	CB.SC.U4CSE23628	KRISHNAN S.
4	CB.SC.U4CSE23661	MADHAV SREEJITH

Guide: **Abirami K.**

Designation, Department of CSE

March 25, 2026

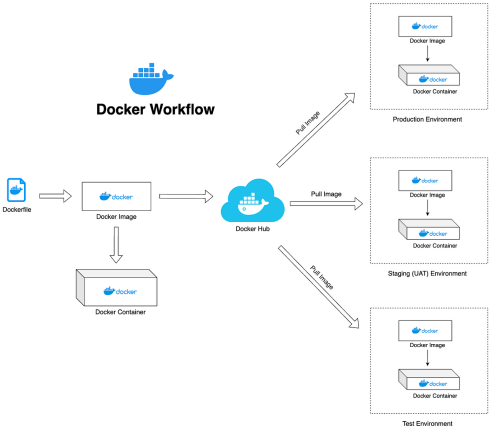
1. Introduction

Overview of Container Security and Risk Prioritization

1.Introduction

Containerization in Modern Systems

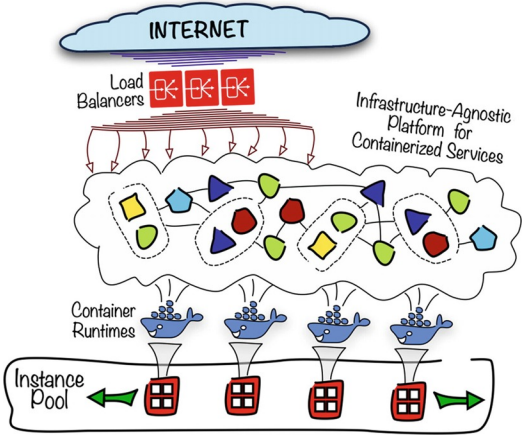
- **Docker** enables packaging of applications with dependencies into lightweight, portable containers.
- Containers provide:
  - **Consistency** across development, testing, and production
  - **Scalability** in cloud-native environments
  - **Efficiency** compared to virtual machines
- Widely adopted in **DevOps and DevSecOps pipelines**



1. Introduction

Security Challenges in Containers

- Public container images often contain:
  - Outdated libraries
  - Vulnerable dependencies
  - Misconfigurations
- Vulnerabilities are tracked as **CVEs (Common Vulnerabilities and Exposures)**
- Scanning tools (Trivy, Snyk, Grype) detect:
  - **Hundreds of vulnerabilities per image**
- **Challenge:** Prioritizing which vulnerabilities to fix first



1. Introduction

Need for Risk-Based Prioritization

- **CVSS (Common Vulnerability Scoring System)** measures severity (0–10)
  - Based on Confidentiality, Integrity, Availability
  - Does NOT indicate real-world exploitation
- **EPSS (Exploit Prediction Scoring System)** predicts exploit likelihood (0–1)
  - Uses real-world threat intelligence
- **Key Insight:**
  - High severity $\neq$ High risk
  - Exploit probability is critical
- **Goal:** Combine severity + exploitability + context for better prioritization

2. Problem Statement and Motivation

The Gap Between Severity and Exploitability

2. Problem Statement and Motivation

Problem Statement

To overcome ineffective CVE prioritization in containerized environments, an EPSS-augmented, automated risk-aware system is proposed to identify, prioritize, and mitigate container image vulnerabilities by combining exploit likelihood, CVSS severity, and deployment context throughout the DevSecOps pipeline.

Motivation

As containerized applications form the backbone of modern software delivery, efficient vulnerability management is critical. A structured, risk-based CVE prioritization framework that integrates severity assessment, exploit prediction, and contextual risk factors is necessary to identify high-risk vulnerabilities and enable timely, informed remediation in DevSecOps pipelines.

2. Problem Statement and Motivation

The "Prioritization Gap" in Container Security

The Current State of DevSecOps:

- **Registry Risk:** Modern pipelines rely on Docker Hub/GHCR images often pre-loaded with CVEs and misconfigurations.
- **Scanner Fatigue:** Tools like Trivy or Snyk flag 100–300+ vulnerabilities per image, making manual triage impossible.

The Flaw in CVSS-Only Defense:

- **Theoretical vs. Actual:** CVSS measures *potential impact*, not the *probability of exploit*.
- **Misaligned Priority:** A CVSS 9.8 (no known exploit) currently takes precedence over a CVSS 6.5 being actively exploited in the wild.

3. Literature Survey & Research Direction

Survey Extensiveness & Research Justification

3. Literature Survey & Research Direction

Survey Scope

- A comprehensive survey was conducted on more than 10 recent analytical research papers in the domain of Docker security, container vulnerability analysis, runtime monitoring, and DevSecOps.
- The survey covers:
  - Static container image scanning (e.g., Trivy, Grype)
  - Runtime monitoring and anomaly detection (Falco, Sysdig)
  - Machine learning-based container attack detection
  - Container hardening and least-privilege enforcement

3. Literature Survey (2 of 3)

Container Vulnerability & Assessment Research

#	Paper Title	Methodology	Year	Key Contributions	Research Gap
1	A Container Security Survey: Exploits, Attacks, and Defenses [1]	Comprehensive Systematic Survey and Threat Taxonomy	2025	Provides a structured classification of container threats across image, runtime, orchestration, and supply-chain layers.	Does not provide a quantitative vulnerability prioritization or exploit-based ranking framework.
2	Security Vulnerabilities in Docker Images: A Cross-Tag Study of Application Dependencies [2]	Large-scale empirical analysis of Docker image tags and dependencies	2025	Shows how vulnerable dependencies propagate across multiple image versions and tags	Does not incorporate exploit likelihood (EPSS) or contextual risk scoring.
3	Container Performance and Vulnerability Management for Container Security Using Docker Engine [3]	Runtime performance monitoring integrated with vulnerability scanning	2022	Integrates container performance monitoring with vulnerability detection mechanisms.	Lacks integration with exploit intelligence sources such as EPSS or KEV correlation.
4	A Robust Framework for Comprehensive Container Image Vulnerability Assessment [4]	Static and dynamic multi-layer container image analysis framework	2025	Enhances detection coverage through static and dynamic multi-layer container image analysis.	Does not propose a composite multi-factor CVE prioritization model.

3. Literature Survey (3 of 3)

Exploit Prediction & Policy Intelligence

#	Paper Title	Methodology	Year	Key Contributions	Research Gap
5	A Novel Vulnerability Exploit Prediction System Using the Relational Vulnerability-Vendor Network [5]	Graph-based machine learning exploit prediction using vulnerability–vendor relationships	2025	Improves exploit prediction accuracy using graph-based machine learning over vulnerability–vendor relationships	Not specifically tailored to container ecosystems or DevSecOps pipelines
6	Enhancing Vulnerability Prioritization: Data-Driven Exploit Predictions with Community-Driven Insights [6]	Machine learning with community threat intelligence signals	2023	Demonstrates improved exploit prediction beyond traditional CVSS scoring	Does not integrate container-specific reachability or runtime context.
7	A Technical Overview of Docker Container Security Threats [7]	Architectural and threat-surface analysis of Docker ecosystems	2025	Systematically categorizes Docker-specific attack vectors and threat surfaces.	Lacks experimental validation or automated mitigation mechanisms.
8	BEACON: Automatic container policy generation using environment-aware dynamic analysis [8]	Dynamic behavior monitoring and automatic policy synthesis	2025	Automatically generates least-privilege container runtime policies using dynamic behavioral analysis	Focuses on runtime hardening rather than vulnerability prioritization or CVE ranking.

3. Literature Survey Summary & Research Gap

State-of-the-Art vs. Proposed Framework

Feature / Capability	**Industry Tools** *(Trivy, Docker-Scout)*	**Academic SOTA** *(Recent Papers)*	**Our Proposed Framework** *(EPSS-Augmented Triage)*
Vulnerability Detection	Yes	Yes	Yes (via Trivy engine)
Severity Scoring	CVSS Only	CVSS + ML	Composite (CVSS + EPSS) + ML
Exploit Probability	No (Or manual filter)	Yes (Isolated)	Yes (Integrated in CI/CD)
Runtime Context	No	Limited (Syscalls)	Static/Dynamic Reachability

The Identified Gap: While tools exist for detection (Trivy) and metrics exist for probability (EPSS), no automated framework mathematically fuses these signals with runtime context to prevent DevSecOps alert fatigue.

Research Direction

The Goal: A composite scoring system combining severity, exploitability, and reachability.

Data Collection & Enrichment Pipeline:

- Scan container images using Trivy to extract CVE data and CVSS scores.
- Enrich each CVE with live EPSS scores via the FIRST public API.
- Incorporate runtime reachability as a third prioritization factor.

Weighting Strategy:

- **Phase 1:** Heuristic weight assignment for CVSS, EPSS, and reachability.
- **Phase 2:** ML-optimized weights using XGBoost trained on CISA KEV ground truth.

4. Methodology

Proposed EPSS-Augmented CVE Prioritization Framework

4. Methodology

Overall Approach

- Proposed system performs **multi-factor CVE prioritization** using:
  - **CVSS** -> Severity
  - **EPSS** -> Exploit Probability
  - **Reachability** -> Runtime relevance
- Goal: Generate a **composite risk score** for each vulnerability
- Enables:
  - Accurate prioritization
  - Reduced alert fatigue
  - Faster remediation decisions

4. Methodology

Data Collection and Enrichment

- **Step 1: Container Scanning**
  - Use **Trivy** to scan container images
  - Extract CVEs and CVSS scores
- **Step 2: EPSS Integration**
  - Fetch EPSS scores using **FIRST API**
  - Map EPSS values to each CVE
- **Step 3: Data Enrichment**
  - Combine CVSS + EPSS into unified dataset

4. Methodology

Reachability Analysis

- Determines whether a vulnerable component is **actually used at runtime**
- Performed using:
  - Static analysis of container filesystem
  - Dependency inspection
- Benefits:
  - Reduces false positives
  - Prioritizes exploitable vulnerabilities only
- Output: **Reachability Score** (0 or 1)

4. Methodology

Composite Risk Scoring

- **Phase 1:**
  - Assign heuristic weights (w_1, w_2, w_3)
- **Phase 2:**
  - Optimize weights using **XGBoost**
  - Train on **CISA KEV dataset**
- Output: Ranked list of vulnerabilities

4. Methodology

System Workflow

- Input: Container Image
- Pipeline:
  1. Scan image (Trivy)
  2. Extract CVEs + CVSS
  3. Fetch EPSS scores
  4. Perform reachability analysis
  5. Compute composite risk score
- Output:
  - Ranked CVE list
  - JSON / HTML report
- Integrated into **CI/CD pipeline**

5. Originality of Work

Addressing the CVSS-Only Limitation

5. Originality of Work

Addressing the CVSS-Only Limitation

- **Beyond Static Severity:** Existing tools treat all high-CVSS CVEs equally, regardless of exploit probability.
- **Risk-Calibrated Output:** Our framework adds **EPSS (Exploit Prediction Scoring System)** as a first-class signal, providing developers with actionable, threat-informed data.

Novel Composite Scoring Framework

- **First-of-its-kind:** Combines $CVSS + EPSS + Reachability$ specifically for container image triage.
- **Gap Fulfillment:** Directly addresses the lack of automated, multi-factor prioritization identified across all surveyed works.

5. Originality of Work

Integration and Benchmarking

- **End-to-End CI/CD Integration:** Designed to operate as a native pipeline gate rather than a standalone scanner, producing automated JSON/HTML ranked reports.

Benchmarkable Research Contribution

- **Ranking as a Science:** Evaluates vulnerability triage using **NDCG@10** (Normalized Discounted Cumulative Gain), treating it as a formal information retrieval problem.
- **Empirical Ground Truth:** Utilizes the **CISA KEV** (Known Exploited Vulnerabilities) catalog to validate the accuracy of the composite scoring vs. CVSS-only baselines.

6. Technical Knowledge

Algorithms, Models, and Scoring Metrics

6. Technical Knowledge

Foundation: CVSS vs. EPSS

1. CVSS (Common Vulnerability Scoring System)

The "Severity" Metric (0–10): Measures theoretical impact on Confidentiality, Integrity, and Availability. It identifies how bad a bug *could* be, but not if it *is* being used.[9]

2. EPSS (Exploit Prediction Scoring System)

The "Probability" Metric (0–1): An ML model trained on real-world threat intel (Dark Web, PoC repos). Predicts the likelihood of exploitation within 30 days.[10]

- *Note: EPSS v3 (2023) achieves $\approx$ 82% AUC in exploit prediction.*

- **Reachability Analysis:** Static inspection of the container filesystem to determine if a vulnerable library is actually invoked at runtime.

6. Technical Knowledge

Composite Risk Model Architecture Diagram

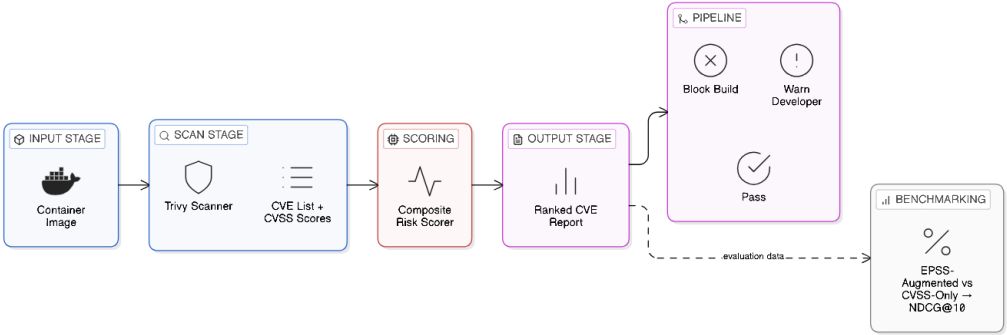


Figure: Multi-Factor CVE Prioritization Architecture integrating CVSS, EPSS, Reachability.

References I

P. Vyas, S. Singh, and R. Mukkamala, “A container security survey: Exploits, attacks, and defenses,” *ACM Computing Surveys*, 2025. [Online]. Available: https://doi.org/10.1145/3715001

J. Li and H. Wang, “Security vulnerabilities in Docker images: A cross-tag study of application dependencies,” *IEEE Transactions on Software Engineering*, 2025. [Online]. Available: https://ieeexplore.ieee.org/document/11186048

S. Prathap and S. S. Kumar, “Container performance and vulnerability management for container security using Docker engine,” *Security and Communication Networks*, vol. 2022, 2022. [Online]. Available: https://onlinelibrary.wiley.com/doi/full/10.1155/2022/6819002

A. Khan, R. Patel, and D. Sharma, “A robust framework for comprehensive container image vulnerability assessment,” *IEEE Access*, 2025. [Online]. Available: https://ieeexplore.ieee.org/document/10902061

L. Jiang, M. Wei, and T. Zhang, “A novel vulnerability exploit prediction system using the relational vulnerability-vendor network,” *Proceedings of the ACM on Software Engineering*, 2025. [Online]. Available: https://doi.org/10.1145/3724133

Y. Zhou and X. Chen, “Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights,” *IEEE Access*, 2023. [Online]. Available: https://ieeexplore.ieee.org/document/10190703

M. Gupta and R. Rastogi, “A technical overview of Docker container security threats,” in *Lecture Notes in Networks and Systems*. Springer, 2025, vol. 981. [Online]. Available: https://doi.org/10.1007/978-981-96-4509-1_27

References II

- Z. Wang, Y. Liu, and K. Zhou, “BeaCon: Automatic container policy generation using environment-aware dynamic analysis,” *Computers & Security*, vol. 148, 2025. [Online]. Available: https://www.sciencedirect.com/science/article/pii/S016740482500478X#bib0012
- FIRST.Org, Inc., “Common vulnerability scoring system (cvss),” https://www.first.org/cvss/, Forum of Incident Response and Security Teams (FIRST), 2026, accessed: 2026-02-23.
- Forum of Incident Response and Security Teams (FIRST), “Exploit prediction scoring system (epss),” 2025, accessed: 2026-02-23. [Online]. Available: https://www.first.org/epss/
- Cybersecurity and Infrastructure Security Agency (CISA), “Known exploited vulnerabilities catalog,” 2026, accessed: 2026-02-23. [Online]. Available: https://www.cisa.gov/known-exploited-vulnerabilities-catalog

Thank You